

INTRODUÇÃO

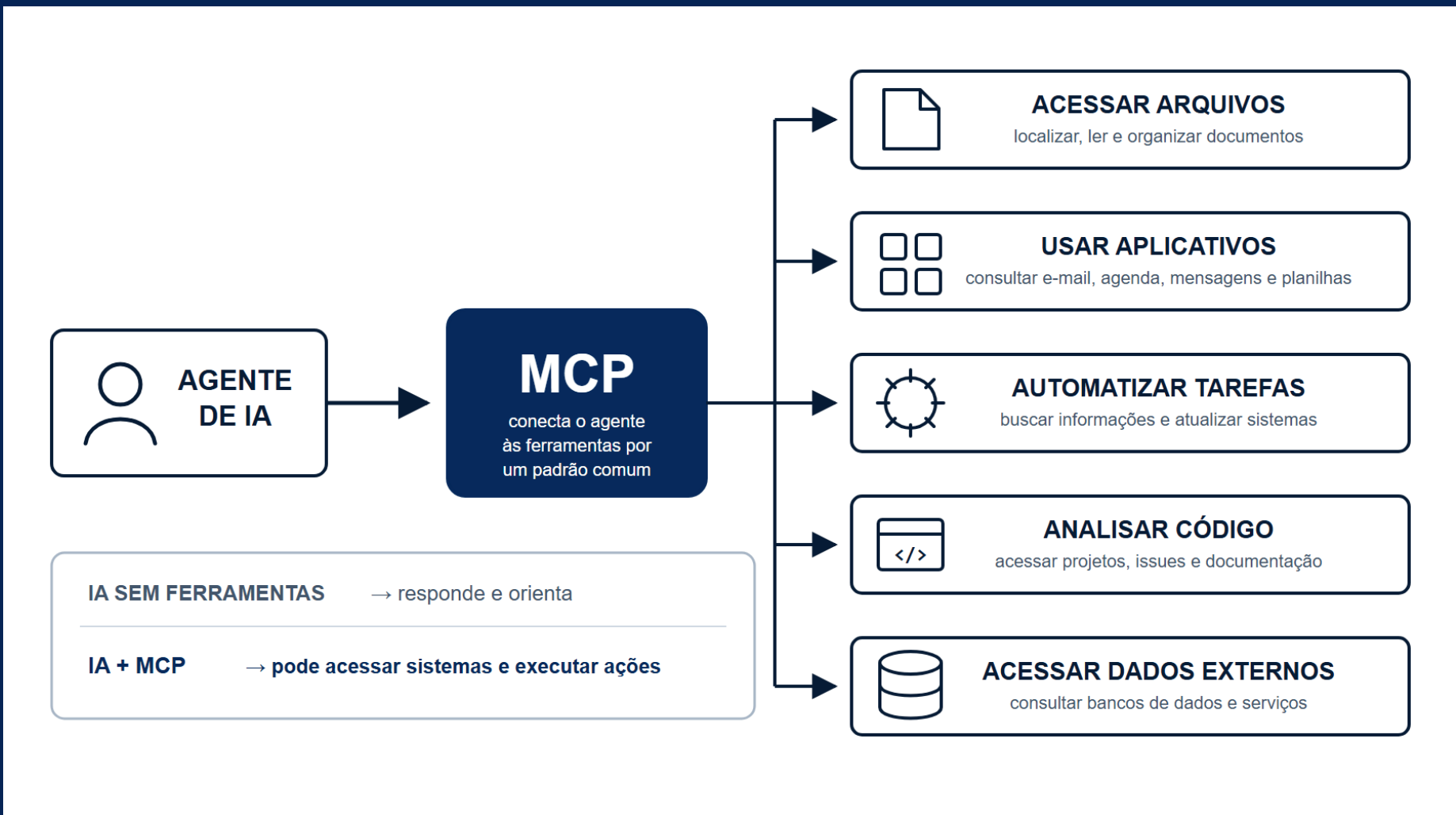
Agentes de IA e o Model Context Protocol

Agentes de inteligência artificial deixaram de apenas gerar textos e passaram a interagir com arquivos, bancos de dados, APIs e outros sistemas. O Model Context Protocol (MCP) proposto pela Anthropic em 2024 padroniza essa integração ao permitir que servidores externos ofereçam ferramentas a aplicações de IA. Essa arquitetura amplia as capacidades dos agentes, mas também cria uma nova fronteira de segurança: uma ferramenta autorizada pode executar ações fora do próprio modelo e acessar recursos que exigem controle e supervisão.

JUSTIFICATIVA

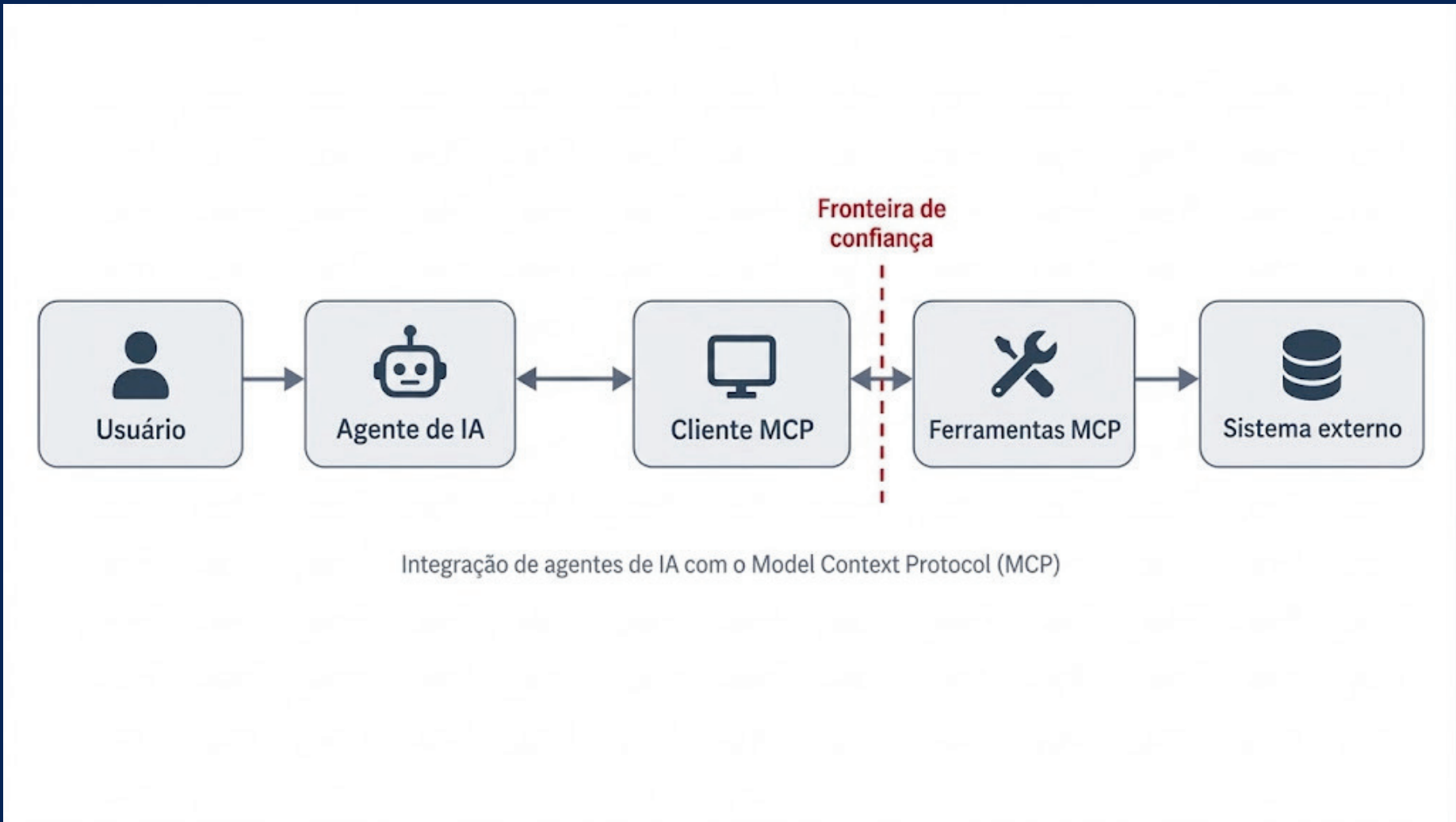
- Mudanças perigosas após a aprovação: No ataque Rug Pull, uma ferramenta legítima é modificada após ser aprovada: nome, descrição e parâmetros podem permanecer iguais, enquanto o código passa a executar ações não autorizadas, mantendo a confiança da versão anterior (Bhatt et al., 2025).
- Risco real e difícil de identificar: Em 2025, o pacote postmark-mcp recebeu uma atualização maliciosa que passou a enviar cópias ocultas dos e-mails para um atacante (Postmark, 2025). Segundo Song et al. (2026), em estudo publicado pelo IEEE, pesquisadores revelaram a 20 participantes quais servidores eram maliciosos e pediram que identificassem como os ataques funcionavam. Mesmo assim, apenas 1 dos participantes identificou corretamente o ataque Rug Pull.
- Reconhecimento do risco e crescimento do ecossistema: Em 2026, a NSA (Agência de Segurança Nacional dos Estados Unidos) alertou que servidores MCP confiáveis podem ter capacidades ou acessos alterados sem nova aprovação, recomendando sua detecção e reavaliação. Segundo a Anthropic (2025), já existem milhares de servidores públicos, e Hasan et al. (2026), na ACM TOSEM, apontam que mecanismos tradicionais de segurança não cobrem todas as vulnerabilidades específicas do MCP.
- Da detecção à reavaliação: Hash identifica que uma ferramenta mudou, mas não se a alteração é perigosa. Inspirada na triagem de alertas com IA já utilizada na cibersegurança (Tariq et al., 2025), esta pesquisa compara hash, interface, código e análise combinada para distinguir alterações legítimas de maliciosas.

O que o MCP permite fazer?



Fonte: elaboração própria com ferramenta de IA, 2026.

Funcionamento do MCP



Fonte: elaborado pelos autores com base em Model Context Protocol (2026).

PROBLEMA

Quais estratégias de verificação conseguem identificar mudanças perigosas em ferramentas MCP previamente aprovadas, sem bloquear atualizações legítimas?

HIPÓTESE

Estratégias que analisam semanticamente as mudanças devem distinguir melhor alterações maliciosas de atualizações legítimas do que verificações puramente baseadas em alteração de arquivos, e a combinação de diferentes fontes de evidência pode reduzir os pontos cegos das análises isoladas, porém aumentando custo e tempo necessários.

OBJETIVO

Comparar estratégias para detectar mudanças maliciosas em ferramentas MCP após sua aprovação, avaliando capacidade de detecção, bloqueios incorretos, tempo e custo, e identificar quais evidências podem fundamentar mecanismos de reavaliação como o MCP Sentry.

EVIDÊNCIAS COMPLEMENTARES E VIABILIDADE

POR QUE COMBINAR EVIDÊNCIAS?

O resultado de 38% de C1 concentrou-se nos casos em que interface ou metadados revelavam o risco: 65 de 80 decisões válidas (81%). Quando permaneceram aparentemente normais, C1 não bloqueou nenhuma: 0 de 89.

Assim, interface e código observam superfícies diferentes. A análise do código cobre comportamentos que não aparecem externamente e, combinadas, as evidências alcançaram 84% de detecção.

VIABILIDADE OPERACIONAL

Na condição combinada, o GPT-5.6 Luna bloqueou **91,7%** das mudanças perigosas e liberou 100% das legítimas nos cenários avaliados. O custo de inferência observado foi de aproximadamente **US\$ 0,00046** por execução, com latência mediana de 2,7 segundos.

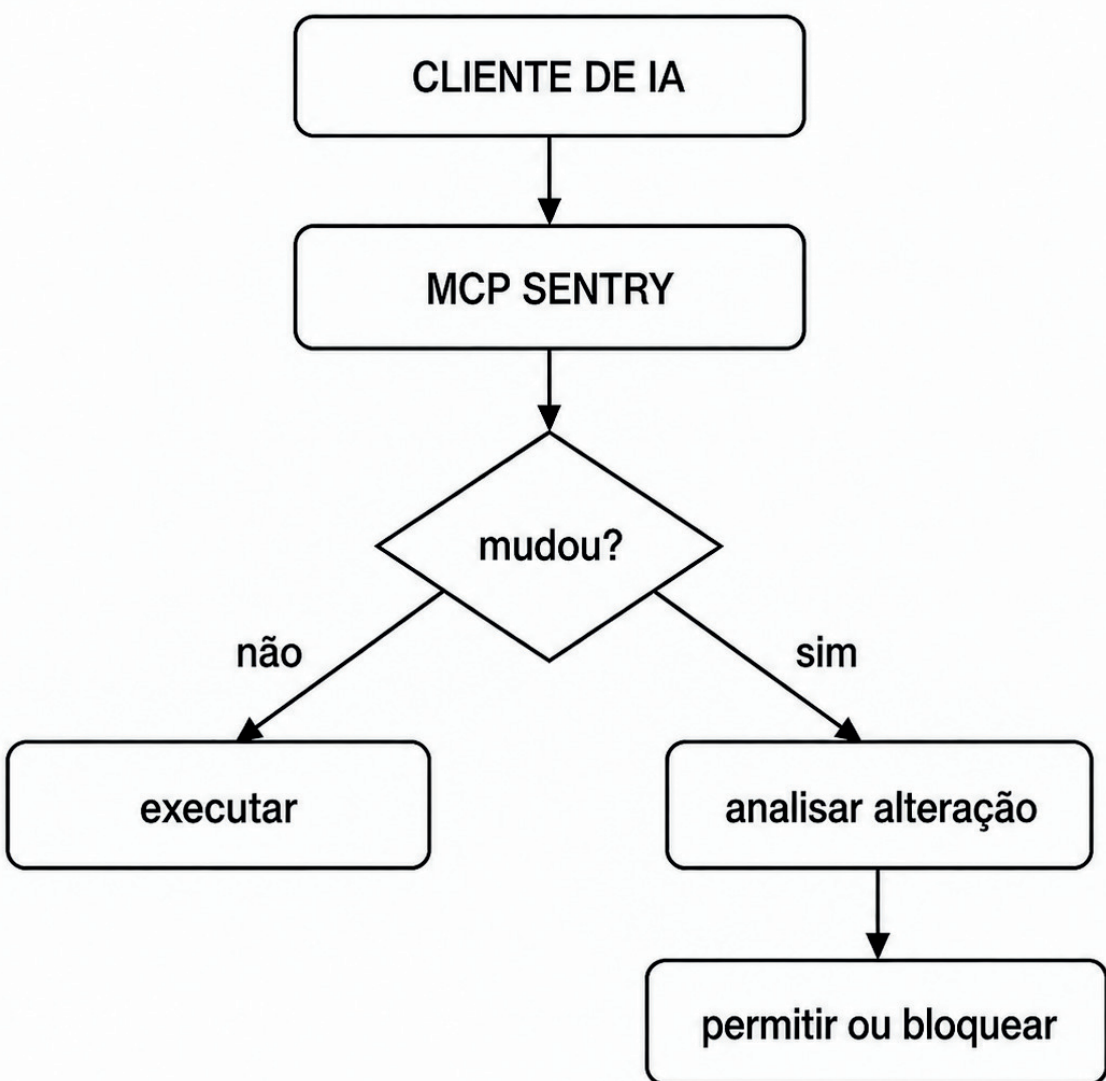
Os resultados indicam que a IA pode apoiar a reavaliação de ferramentas MCP com baixo custo operacional. A revisão continua necessária para mudanças não detectadas e casos inconclusivos.

MCP SENTRY — APLICAÇÃO OPERACIONAL

A pesquisa também fundamentou o desenvolvimento de um gateway local que fica entre o cliente de IA e o servidor MCP. Antes de iniciar o servidor, o MCP Sentry verifica se o código, os metadados ou as configurações foram alterados.

Quando encontra uma mudança, o MCP Sentry compara a versão atual com a aprovada e apresenta as diferenças à IA do cliente. Se a mudança for considerada segura, o servidor poderá ser iniciado. Caso represente um risco, ele continuará bloqueado e o motivo será registrado.

Fluxo operacional do MCP Sentry



Fonte: Os autores 2026.

CONCLUSÕES

Ao final desta etapa do projeto, concluiu-se que o objetivo de comparar estratégias para identificar mudanças perigosas em ferramentas MCP foi atingido. Os resultados evidenciaram limitações nas verificações isoladas. No núcleo N-INT, a combinação de interface e código apresentou o melhor equilíbrio, bloqueando 84% das mudanças perigosas e permitindo 88% das benignas entre as decisões válidas.

Além dos resultados experimentais, o trabalho produziu um dataset de cenários de rug pull em ferramentas MCP, utilizado na avaliação das estratégias, e originou uma aplicação prática. Em uma demonstração controlada, foi simulada uma alteração maliciosa em um servidor MCP previamente aprovado. O gateway detectou a mudança, gerou um relatório para revisão e, após a alteração ser classificada como perigosa, manteve o servidor bloqueado antes de sua inicialização. Dessa forma, no cenário testado, o ataque não chegou a ser executado, demonstrando a viabilidade prática da estratégia proposta.

Embora os principais objetivos tenham sido atingidos, ainda há potencial para melhorias. O dataset pode ser ampliado para incluir maior diversidade de alterações perigosas e benignas, permitindo verificar se os resultados se mantêm em novos cenários. Também podem ser realizados testes controlados mais próximos do uso real, avaliando o funcionamento e as limitações da proposta de defesa em condições variadas. A aplicação ainda pode ser aprimorada, especialmente nos processos de instalação, configuração e uso.

REFERÊNCIAS

- ANTHROPIC. Introducing the Model Context Protocol. 2024. Disponível em: anthropic.com/news/model-context-protocol. Acesso em: 11 set. 2026.
- ANTHROPIC. Donating the Model Context Protocol and establishing the Agentic AI Foundation. 2025. Disponível em: anthropic.com/news/donating-the-model-context-protocol-and-establishing-of-the-agentic-ai-foundation. Acesso em: 11 set. 2026.
- BHATT, M.; NARAJALA, V. S.; HABLER, I. ETDI: Mitigating Tool Squatting and Rug Pull Attacks in Model Context Protocol (MCP) by using OAuth-Enhanced Tool Definitions and Policy-Based Access Control. arXiv:2506.01333, 2025. Disponível em: arxiv.org/abs/2506.01333. Acesso em: 12 set. 2026.
- HASAN, M. M. et al. Model Context Protocol (MCP) at First Glance: Studying the Security and Maintainability of MCP Servers. ACM Transactions on Software Engineering and Methodology, 2026. DOI: 10.1145/3814959. Disponível em: doi.org/10.1145/3814959. Acesso em: 12 set. 2026.
- HUANG, Y. et al. From Component Manipulation to System Compromise: Understanding and Detecting Malicious MCP Servers. arXiv:2604.01905, 2026. Disponível em: arxiv.org/abs/2604.01905. Acesso em: 13 set. 2026.
- MODEL CONTEXT PROTOCOL. Architecture. 2025. Disponível em: modelcontextprotocol.io/specification/2025-06-18/architecture. Acesso em: 13 set. 2026.
- NATIONAL SECURITY AGENCY. Model Context Protocol (MCP): Security Design Considerations for AI-Driven Automation. 2026. Disponível em: nsa.gov. Acesso em: 14 set. 2026.
- POSTMARK. Information Regarding Malicious "postmark-mcp" Package. 2025. Disponível em: postmarkapp.com/blog/information-regarding-malicious-postmark-mcp-package. Acesso em: 14 set. 2026.
- SONG, H. et al. Beyond the Protocol: Unveiling Attack Vectors in the Model Context Protocol (MCP) Ecosystem. IEEE Transactions on Software Engineering, v. 52, n. 8, p. 2410–2426, 2026. DOI: 10.1109/TSE.2026.3694876. Disponível em: doi.org/10.1109/TSE.2026.3694876. Acesso em: 15 set. 2026.
- TARIQ, S. et al. Alert Fatigue in Security Operations Centres: Research Challenges and Opportunities. ACM Computing Surveys, v. 57, n. 9, art. 224, p. 1–38, 2025. DOI: 10.1145/3723158. Disponível em: doi.org/10.1145/3723158. Acesso em: 15 set. 2026.
- WANG, Z. et al. MCPTox: A Benchmark for Tool Poisoning on Real-World MCP Servers. Proceedings of the AAAI Conference on Artificial Intelligence, v. 40, n. 42, p. 35811–35819, 2026. DOI: 10.1609/aaai.v40i42.40895. Disponível em: doi.org/10.1609/aaai.v40i42.40895. Acesso em: 16 set. 2026.
- YANG, Y.; WU, D.; CHEN, Y. MCPSecBench: A Systematic Security Benchmark and Playground for Testing Model Context Protocols. arXiv:2508.13220, 2025. Disponível em: arxiv.org/abs/2508.13220. Acesso em: 16 set. 2026.